Nome da Máquina: Write Up

Plataforma: HackTheBox



Máquina / Desafio:	Touch
Dificuldade:	Fácil
Autor:	Lurian Lima (luricl)
Matrícula:	222005395

18 de outubro de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **3**

4 Movimentação Lateral **5**

5 Escalada de Privilégios **5**

6 Conclusão **5**

7 Referências **5**

1 Visão Geral

2 Reconhecimento

Inicialmente, foi feita um reconhecimento usando o Nmap. Foi necessário adicionar a flag -Pn para evitar que o Nmap seja barrado pelo firewall ao tentar checar se há conexão. Com a flag, o Nmap parte direto para o scan.

```
$ nmap -sV -T4 -Pn <TARGET_IP>
Starting Nmap 7.992 ( https://nmap.org ) at 2026-10-18 17:28 -0300
Nmap scan report for <TARGET_IP> (<TARGET_IP>)
Host is up (0.13s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE SERVICE       VERSION
135/tcp  open  msrpc         Microsoft Windows RPC
3389/tcp open  ms-wbt-server Microsoft Terminal Service
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
8443/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://
   nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.81 seconds
```

Listing 1: Varredura de portas com Nmap

Como resultados, percebemos que o alvo é um host Windows (indicado pela linha `Service Info`), com quatro portas TCP abertas e 996 portas filtradas, ou seja, que não respondem. Essa proporção indica que um firewall descarta a maior parte do tráfego e deixa passar apenas alguns serviços, o que restringe a superfície de ataque a eles:

- **135/tcp (MSRPC):** *endpoint mapper* do RPC, usado por serviços do Windows para se registrarem e serem localizados. Pode ser enumerado depois para listar interfaces RPC, mas não dá acesso por si só.
- **3389/tcp (RDP):** Remote Desktop Protocol. Exige credenciais válidas, portanto só é útil após a obtenção de um usuário e senha.
- **5985/tcp (WinRM):** Windows Remote Management sobre HTTP, que permite executar comandos PowerShell remotamente. Também exige credenciais, mas é um dos caminhos mais diretos de acesso quando se possui uma conta válida.
- **8443/tcp (HTTP):** serviço web executado pelo `Microsoft HTTPAPI`. É a única porta com uma aplicação web aparente, e por isso é o ponto de partida natural para a análise.

Duas observações sobre a saída merecem atenção. Primeiro, a etiqueta `(SSDP/UPnP)` nas portas 5985 e 8443 não descreve o serviço real: o Nmap a atribui por correspondência de assinatura com o `HTTPAPI`, o servidor HTTP nativo do Windows, e não há indício de UPnP no alvo. Segundo, a porta 8443 foi identificada como HTTP e não como HTTPS, o que precisa ser confirmado manualmente, pois portas dessa família costumam usar TLS.

A porta 445 (SMB), comum em hosts Windows, não aparece entre as abertas. Como as portas não listadas são todas filtradas, ela não pode ser usada diretamente a partir desta varredura. Os próximos passos são verificar a aplicação na porta 8443 e confirmar o estado da porta 445.

Podemos verificar se a porta 445 está aberta usando o nmap novamente.

```
$ nmap -Pn -p 445 --reason <TARGET-IP>
Starting Nmap 7.992 ( https://nmap.org ) at 2026-10-18 17:48 -0300
Nmap scan report for <TARGET-IP> (<TARGET-IP>)
Host is up, received user-set.

PORT    STATE    SERVICE      REASON
445/tcp filtered microsoft-ds no-response

Nmap done: 1 IP address (1 host up) scanned in 2.02 seconds
```

Listing 2: Verificando o estado da porta 445 com Nmap

Esse resultado indica que não houve resposta. Possivelmente, há um firewall descartando as respostas.

Porém, ao acessar o gobuster no link *http://<TARGET-IP>:8443/*, descobrimos alguns diretórios:

```
$  gobuster dir -u http://<TARGET-IP>:8443/ -w /snap/seclists/current/
   Discovery/Web-Content/common.txt -t 50 -s 200,204,301,307,401,403 -b "" -
   o gobuster_8443.txt
..
/api                  (Status: 403) [Size: 35]
/favicon.ico          (Status: 200) [Size: 452]
/login                (Status: 200) [Size: 3572]
Progress: 4750 / 4750 (100.00%)
...
```

Listing 3: Verificando diretórios com gobuster

E, ao acessar o */login*, encontramos a seguinte tela:

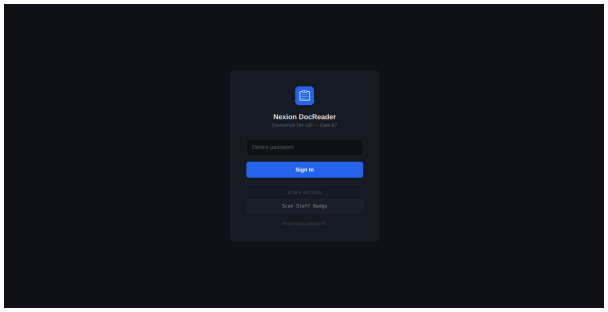


Figura 1: Tela encontrada.

3 Exploração

Examinando o html da página, é possível encontrar uma dica para a senha:

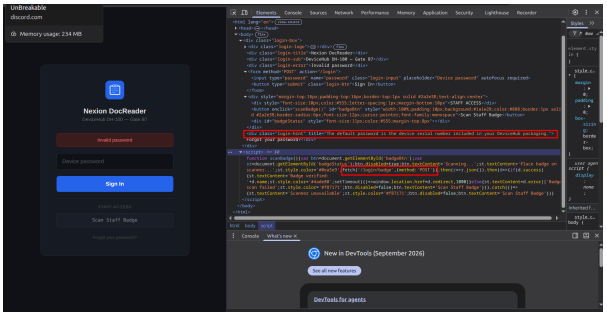


Figura 2: Pistas encontradas no html da tela de login.

Como a dica da senha diz que a senha padrão é o número de série que vem na embalagem do dispositivo. Como não temos a embalagem, o caminho realista é procurar o número de série em algum lugar que o próprio alvo exponha.

Portanto, podemos explorar a rota */api*, que retorna o seguinte resultado:

```
{"error":"Authentication required"}
```

Listing 4: Resultado obtido ao acessar a rota */api*

Porém, o nome da rota sugere que podem haver outras rotas a partir dela, como */api/status/*, */api/info* ou */api/device* que devem entregar informações acerca do dispositivo. Ao acessar */api/status/*, encontramos as informações procuradas:

```
{"device":"Nexion DeviceHub DH-100","serial":"NX-DH-2024-B7042","firmware
   ":"1.4.2","status":"online","uptime":20774}
```

Listing 5: Informações obtidas ao acessar a rota */api/status*

Logo, encontramos o número serial do dispositivo, que também é a senha, e somos redirecionados para a seguinte tela home:

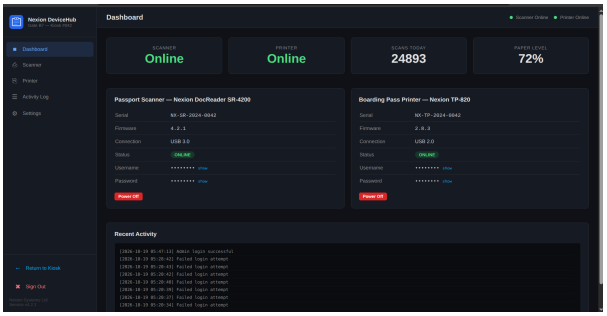


Figura 3: Tela home encontrada após o login.

Navegando para a aba *scanner*, encontramos informações sobre um usuário:

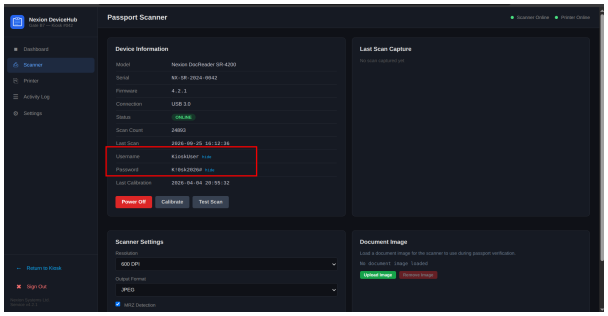


Figura 4: Informações encontradas na tela scanner.

4 Movimentação Lateral

5 Escalada de Privilégios

6 Conclusão

7 Referências

Referências

[1] **OWASP / CVE / Nome da Vulnerabilidade**: Breve descrição técnica do vetor abordado, documentação ou payload de referência.
Disponível em: https://exemplo.com/artigo-ou-documentacao

[2] **Repositório / Autor do Exploit**: Detalhes do exploit público, script ou ferramenta utilizada durante a exploração.
Disponível em: https://github.com/exemplo/repositorio-exploit